KLP BANKS: Staff Data Handling Checklist

One page. Full rules: Handling Matrix. Fictional bank used for training.

1. Know the level first

PUBLIC	INTERNAL	CONFIDENTIAL
Approved for anyone. *Rates already announced, branch details, blank forms, brochures.*	Staff and NDA partners only. *Org charts, circulars, SOPs, budgets.*	Could seriously harm customers, staff, cash or systems. *Customer and employee records, cash positions, lockers, passwords and keys, security reports, logs, unannounced plans.*

Not sure? Treat it as the higher level and ask the data owner. A draft keeps the level of its content until it is approved.

2. Before you act, tick every box

STORE

☐ Only on bank-approved systems. Never personal phones, personal email, personal cloud or unapproved apps.

☐ Confidential: encrypted, minimum copies, paper locked away. USB drives only if bank-issued and encrypted (never for Confidential).

SHARE

☐ Do I have a **need to know**, and does the recipient?

☐ Right recipient? Check the address, and **call back** for Confidential.

☐ Approved channel, encrypted for Confidential, password sent separately.

☐ Never public links, personal email or messaging apps for Internal or Confidential data.

ACCESS

☐ Use your own login and MFA. Never share passwords or use someone else's account.

☐ Only open what your job needs. Curiosity is not a business reason.

☐ Temporary access? Make sure it has an end date.

KEEP

☐ Keep records only as long as the retention schedule says. Old personal data is a risk, not an asset.

☐ Never write passwords, keys or full customer data into logs, tickets, chats or screenshots.

DISPOSE

☐ "Delete" is not disposal. Paper goes to approved shredders.

☐ Devices and drives: IT sanitises or destroys them (purge or destroy for Confidential) and records it.

☐ Never give old devices to vendors or recyclers without a certificate of destruction.

3. If something goes wrong

What to do	How fast
Report anything **suspected or confirmed**: phishing clicked, wrong recipient, lost device, odd access, fake app or page.	**Confidential: within 1 hour.** Internal: within 24 hours. Public (defaced page, fake app): same business day
Report to: the **Security Incident Response contact** (service desk hotline or the incident mailbox).	Do not wait to be sure
Do **not** investigate alone, delete evidence, or try to hide it.	

No blame for good-faith reports. The bank has legal deadlines: **CERT-In within 6 hours**, RBI as directed, and the **Data Protection Board within 72 hours** of becoming aware. Your fast report is what makes these possible.

4. Seven golden rules

1. Classify before you handle.
2. Approved tools only.
3. Need to know, nothing more.
4. Verify before you send.
5. Keep less, delete properly.
6. Never put secrets in logs.
7. See something, report something, fast.

Checklist for training use. Owner: Information Security. Review: annually.